

CONTRALORÍA GENERAL DE LA NACIÓN
República de Colombia

HISTORIAS DE USUARIO
Sistema de Auditoría Inteligente — SAI-CGN
Versión 1.0 | 17 historias de usuario | Mayo 2025

Campo	Detalle
Proyecto	Sistema de Auditoría Inteligente — SAI-CGN
Total historias de usuario	17 HU (HU-01 a HU-17)
Total criterios de aceptación	77 criterios
Metodología	Scrum — Sprints de 3 semanas
Número de sprints planeados	6 sprints (18 semanas ≈ 6 meses)
Elaborado por	Mauricio Torres — Líder de Proyecto
Revisado por	Jorge Patiño — Auditor Líder Senior CGN

ÍNDICE DE HISTORIAS DE USUARIO

ID	Título	Módulo	Sprint	Prioridad
HU-01	Gestión de usuarios y roles del sistema	Usuarios	Sprint 1	Alta
HU-02	Autenticación segura con SSO institucional	Usuarios	Sprint 1	Alta
HU-03	Auditoría completa de acciones del sistema	Seguridad	Sprint 1	Alta
HU-04	Carga y validación de datos fiscales	Ingesta de Datos	Sprint 1-2	Alta
HU-05	Integración automática con sistemas institucionales	Ingesta de Datos	Sprint 2	Alta
HU-06	Detección automática de anomalías con IA	Motor IA	Sprint 2-3	Alta
HU-07	Explicabilidad e interpretación de hallazgos de IA	Motor IA	Sprint 3	Alta
HU-08	Reentrenamiento y monitoreo del modelo de IA	Motor IA	Sprint 4	Media
HU-09	Consulta normativa con asistente conversacional (RAG)	Asistente RAG	Sprint 3	Alta
HU-10	Actualización automática del corpus normativo	Asistente RAG	Sprint 4	Media
HU-11	Creación y planificación de procesos auditores	Gestión Auditorías	Sprint 2	Alta
HU-12	Notificaciones y gestión de evidencias	Gestión Auditorías	Sprint 2-3	Media
HU-13	Generación automática de informes de auditoría	Informes	Sprint 3-4	Alta
HU-14	Reportes ejecutivos y dashboards de gestión	Informes	Sprint 4	Media
HU-15	Registro y gestión de hallazgos fiscales	Trazabilidad	Sprint 3	Alta
HU-16	Seguimiento a planes de mejoramiento	Trazabilidad	Sprint 4	Media
HU-17	Seguridad de datos y cifrado de la información	Seguridad	Sprint 1	Alta

HISTORIAS DE USUARIO — DETALLE

Cada historia de usuario sigue la estructura: rol → acción → beneficio, acompañada de criterios de aceptación verificables en formato Given-When-Then y la definición de terminado (DoD) que debe cumplirse para cerrar la historia en el sprint.

HU-01 Gestión de usuarios y roles del sistema			Prioridad: Alta
Módulo M01 — Usuarios	Rol Administrador	Sprint Sprint 1	RF Relacionados RF-01, RF-02

Historia de Usuario:

Como Administrador del sistema, quiero crear, modificar, desactivar y asignar roles a los usuarios, para garantizar que cada persona acceda únicamente a las funcionalidades que le corresponden según su perfil institucional.

Criterios de Aceptación:

1. El sistema permite crear un usuario con nombre, cédula, correo institucional, cargo y rol asignado.
2. El sistema valida que el correo sea del dominio @contraloria.gov.co antes de crear la cuenta.
3. El administrador puede asignar uno o más roles: Auditor de Campo, Auditor Líder, Analista de Datos, Administrador, Director.
4. Al desactivar un usuario, sus sesiones activas son terminadas inmediatamente.
5. La eliminación de usuario es lógica (registro histórico preservado); no se permite eliminación física.
6. Todas las acciones de administración quedan registradas en el log de auditoría (RF-05).

Definición de Terminado (DoD): Pruebas unitarias aprobadas (≥80% cobertura), revisión de código completada, integración con LDAP verificada en ambiente de staging.

HU-02 Autenticación segura con SSO institucional			Prioridad: Alta
Módulo M01 — Usuarios	Rol Todos los roles	Sprint Sprint 1	RF Relacionados RF-03, RF-04
Historia de Usuario: <i>Como usuario del sistema, quiero iniciar sesión usando mis credenciales institucionales (SSO) y autenticación multifactor, para acceder de forma segura sin gestionar una contraseña adicional.</i>			
Criterios de Aceptación: 7. El sistema integra autenticación SSO mediante SAML 2.0 / LDAP corporativo de la CGN. 8. El sistema implementa MFA (código OTP) para los roles Administrador y Auditor Líder. 9. Tras 3 intentos fallidos de autenticación, la cuenta se bloquea temporalmente por 15 minutos y se envía alerta al administrador. 10. La sesión expira automáticamente tras 30 minutos de inactividad. 11. El sistema registra fecha, hora, IP y dispositivo de cada inicio de sesión exitoso y fallido.			
Definición de Terminado (DoD): SSO integrado y probado con el LDAP de la CGN en ambiente de staging. Pruebas de seguridad de autenticación superadas.			

HU-03 Auditoría completa de acciones del sistema				Prioridad: Alta
--	--	--	--	-----------------

Módulo	Rol	Sprint	RF Relacionados
M08 — Seguridad	Administrador / Auditor Líder	Sprint 1	RF-05, RF-33
Historia de Usuario: <i>Como Administrador, quiero que el sistema registre automáticamente todas las acciones realizadas por cada usuario, para garantizar trazabilidad completa de las operaciones y cumplir con las políticas de seguridad institucional.</i>			
Criterios de Aceptación: - El log registra: usuario, acción, entidad afectada, valor anterior, valor nuevo, fecha/hora (UTC-5), IP de origen. - Los logs son inmutables; ningún usuario (incluido el administrador) puede modificarlos. - Los logs se conservan mínimo 5 años conforme a la política de gestión documental CGN. - El sistema permite exportar logs filtrados por usuario, módulo, rango de fechas y tipo de acción. - Se generan alertas automáticas ante patrones sospechosos: accesos fuera de horario, descargas masivas, modificaciones de configuración.			
Definición de Terminado (DoD): Módulo de logs desplegado en producción. Prueba de no repudio exitosa. Revisión de cumplimiento con oficial de seguridad aprobada.			

HU-04 Carga y validación de datos fiscales			Prioridad: Alta
Módulo	Rol	Sprint	RF Relacionados
M02 — Ingesta de Datos	Analista de Datos	Sprint 1-2	RF-06, RF-07, RF-09
Historia de Usuario: <i>Como Analista de Datos, quiero cargar archivos de información fiscal en múltiples formatos y recibir un reporte automático de validación, para asegurar la calidad e integridad de los datos antes de procesarlos con el motor de IA.</i>			
Criterios de Aceptación: - El sistema acepta archivos CSV, XLSX, XML y JSON de hasta 500 MB por carga. - Tras la carga, el sistema ejecuta automáticamente: validación de formato, verificación de campos obligatorios, detección de duplicados y coherencia de rangos numéricos. - El sistema genera un reporte de validación con semáforo (verde/amarillo/rojo) por cada dimensión de calidad. - Si la validación falla en campos críticos, el sistema rechaza el archivo, describe el error y sugiere corrección. - El analista puede aprobar manualmente registros con errores no críticos antes de procesarlos. - El sistema notifica por correo electrónico al analista cuando la validación finaliza.			
Definición de Terminado (DoD): Pruebas con archivos reales de SECOP y CHIP completadas. Reporte de validación revisado y aprobado por analista de CGN.			

HU-05 Integración automática con sistemas institucionales			Prioridad: Alta
Módulo	Rol	Sprint	RF Relacionados
M02 — Ingesta de Datos	Analista de Datos	Sprint 2	RF-08, RF-10
Historia de Usuario:			

Como Analista de Datos, quiero que el sistema extraiga datos automáticamente de SECOP II, CHIP y SIRECI mediante sus APIs, para mantener la información actualizada sin intervención manual diaria.

Criterios de Aceptación:

- 23. El sistema ejecuta extracciones programadas (schedulers) configurables por el analista: diaria, semanal o mensual.
- 24. El sistema maneja errores de conexión con reintentos automáticos (máximo 3 reintentos con backoff exponencial).
- 25. Cada extracción genera un registro en el historial con: fecha, sistema fuente, volumen extraído, errores encontrados.
- 26. El sistema mantiene versionado de datasets: permite comparar la versión actual con versiones anteriores.
- 27. El analista recibe notificación si la extracción automática falla por más de 24 horas.

Definición de Terminado (DoD): Integraciones con SECOP II (REST), CHIP (SOAP) y SIRECI (REST) probadas en ambiente de staging. Scheduler funcionando sin intervención por 7 días continuos.

HU-06 Detección automática de anomalías con IA			Prioridad: Alta
Módulo M03 — Motor IA	Rol Auditor de Campo / Analista de Datos	Sprint Sprint 2-3	RF Relacionados RF-11, RF-12
Historia de Usuario: <i>Como Auditor de Campo, quiero que el sistema analice automáticamente los datos contractuales y presupuestales usando IA para identificar anomalías y clasificarlas por nivel de riesgo, de modo que pueda enfocar mi trabajo en los casos más críticos.</i>			
Criterios de Aceptación: 28. El motor de IA analiza datos de contratos, presupuestos y transferencias buscando: valores atípicos, fraccionamiento de contratos, contratistas recurrentes irregulares y concentración de adjudicaciones. 29. Cada anomalía detectada es clasificada automáticamente en: Riesgo Alto (posible hecho punible), Riesgo Medio (irregularidad disciplinable) o Riesgo Bajo (inconsistencia administrativa). 30. Los hallazgos se presentan en un dashboard con filtros por entidad, período, tipo de anomalía y nivel de riesgo. 31. El modelo alcanza una precisión mínima del 75% y recall del 70% en el dataset de validación. 32. El auditor puede exportar la lista de hallazgos en formato XLSX o PDF.			
Definición de Terminado (DoD): Modelo entrenado y validado con dataset anonimizado CGN. Métricas de desempeño (precisión, recall, F1) documentadas y aprobadas por analista CGN.			
HU-07 Explicabilidad e interpretación de hallazgos de IA			Prioridad: Alta
Módulo M03 — Motor IA	Rol Auditor de Campo / Auditor Líder	Sprint Sprint 3	RF Relacionados RF-13, RF-14
Historia de Usuario:			

Como Auditor de Campo, quiero que el sistema me explique en lenguaje comprensible por qué el motor de IA identificó un hallazgo como anomalía, para poder validarlo, documentarlo con sustento técnico y defenderlo en instancias legales.

Criterios de Aceptación:

- 33. Para cada hallazgo, el sistema muestra: variables que más influyeron en la detección (SHAP values), comparación con el comportamiento normal esperado, y porcentaje de confianza del modelo.
- 34. La explicación se presenta en lenguaje fiscal-jurídico colombiano, no en lenguaje técnico de ML.
- 35. El auditor puede marcar un hallazgo como 'Validado', 'Rechazado' o 'En revisión' con una nota justificativa.
- 36. Los hallazgos rechazados alimentan el proceso de reentrenamiento del modelo (feedback loop).
- 37. El sistema adjunta automáticamente la explicación del modelo al informe de auditoría como anexo técnico.

Definición de Terminado (DoD): Implementación de SHAP revisada por científico de datos. Prueba de usuario con 3 auditores CGN completada con satisfacción $\geq 4/5$.

HU-08 Reentrenamiento y monitoreo del modelo de IA			Prioridad: Media
Módulo M03 — Motor IA	Rol Analista de Datos	Sprint Sprint 4	RF Relacionados RF-15, RF-16
Historia de Usuario: <i>Como Analista de Datos, quiero que el sistema reentrene periódicamente los modelos de IA con los datos validados por los auditores y me muestre métricas de desempeño actualizadas, para garantizar que el motor sea cada vez más preciso.</i>			
Criterios de Aceptación: 38. El sistema programa reentrenamientos automáticos trimestrales o cuando el conjunto de datos validados supere 1.000 nuevos registros. 39. El analista puede iniciar un reentrenamiento manual desde el panel de administración. 40. El dashboard de monitoreo muestra: evolución histórica de precisión, recall y F1-score; distribución de hallazgos por categoría; y tasa de aceptación/rechazo de auditores. 41. El sistema conserva las versiones anteriores del modelo y permite hacer rollback si la nueva versión tiene peor desempeño. 42. Se envían alertas al analista si la precisión del modelo cae por debajo del 70%.			
Definición de Terminado (DoD): Pipeline de reentrenamiento automatizado probado con ciclo completo end-to-end. Dashboard de métricas revisado y aprobado por analista CGN.			

HU-09 Consulta normativa con asistente conversacional (RAG)			Prioridad: Alta
Módulo M04 — Asistente RAG	Rol Auditor de Campo / Especialista Legal	Sprint Sprint 3	RF Relacionados RF-17, RF-18, RF-20
Historia de Usuario:			

Como Auditor de Campo, quiero hacer preguntas en lenguaje natural sobre la normativa fiscal y de contratación colombiana y recibir respuestas precisas con citas de fuentes, para resolver dudas jurídicas sin necesidad de consultar manualmente los textos legales.

Criterios de Aceptación:

- 43. El asistente responde preguntas en español sobre: Estatuto de Contratación (L.80/93 y L.1150/07), Ley de Presupuesto, Código Disciplinario Único, Código Penal (delitos fiscales) y resoluciones orgánicas CGN.
- 44. Cada respuesta incluye: cita exacta de la norma (artículo, inciso, párrafo), nombre de la ley y fecha de vigencia.
- 45. El asistente indica el nivel de confianza de la respuesta (Alto / Medio / Bajo) y advierte cuando la pregunta está fuera de su dominio.
- 46. El asistente responde en menos de 5 segundos el 95% de las consultas.
- 47. El auditor puede guardar respuestas del asistente como evidencia dentro de un hallazgo.
- 48. El sistema registra todas las consultas realizadas para análisis de uso y mejora continua.

Definición de Terminado (DoD): Prueba de precisión con 50 preguntas normativas reales: score $\geq$ 80% de respuestas correctamente citadas. Aprobado por especialista legal CGN.

HU-10 Actualización automática del corpus normativo			Prioridad: Media
Módulo M04 — Asistente RAG	Rol Analista de Datos	Sprint Sprint 4	RF Relacionados RF-19
Historia de Usuario: <i>Como Analista de Datos, quiero que el sistema detecte y procese automáticamente nuevas publicaciones normativas del Diario Oficial relacionadas con contratación y fiscalización, para que el asistente conversacional siempre responda con la normativa más actualizada.</i> Criterios de Aceptación: 49. El sistema monitorea diariamente el portal del Diario Oficial (diariooficial.gov.co) y el sistema SUIN-Juriscal. 50. Al detectar una nueva norma relevante (filtrada por categorías fiscales y de contratación), la indexa automáticamente en el corpus del asistente. 51. El analista recibe una notificación con el resumen de las normas incorporadas y puede aprobar o rechazar su inclusión. 52. El sistema lleva un registro versionado del corpus: qué normas se agregaron, modificaron o derogaron y en qué fecha. 53. Si una norma anterior es derogada, el asistente deja de citarla y referencia la norma vigente. Definición de Terminado (DoD): Proceso de indexación automática probado con 3 normas nuevas. Revisado por especialista legal CGN sin errores de contenido.			

HU-11 Creación y planificación de procesos auditores			Prioridad: Alta
Módulo M05 — Gestión Auditorías	Rol Auditor Líder	Sprint Sprint 2	RF Relacionados RF-21, RF-22
Historia de Usuario: <i>Como Auditor Líder, quiero crear y planificar procesos de auditoría asignando equipo, alcance, fechas y fases, para gestionar de manera organizada todas las auditorías a mi cargo y hacer seguimiento de su avance en tiempo real.</i>			

Criterios de Aceptación:

- 54. El sistema permite crear una auditoría con: nombre, entidad auditada, NIT, tipo (regular, especial, fiscal), período auditado, fecha inicio, fecha fin y auditor líder responsable.
- 55. El sistema gestiona el ciclo de vida completo: Planeación → Ejecución → Informe Preliminar → Traslado → Informe Definitivo → Seguimiento → Cierre.
- 56. El auditor líder puede asignar auditores de campo a la auditoría con roles y responsabilidades específicas.
- 57. El sistema muestra un tablero Kanban con el estado de todas las auditorías activas del auditor líder.
- 58. El avance de la auditoría se calcula automáticamente con base en las tareas completadas.

Definición de Terminado (DoD): Flujo completo del ciclo de vida probado de extremo a extremo. Revisado y aprobado por 2 auditores líderes CGN en sesión de aceptación.

HU-12 | Notificaciones y gestión de evidencias

Prioridad: Media

Módulo
M05 — Gestión Auditorías

Rol
Auditor de Campo

Sprint
Sprint 2-3

RF Relacionados
RF-23, RF-24

Historia de Usuario:

Como Auditor de Campo, quiero recibir notificaciones oportunas sobre mis tareas y plazos, y poder adjuntar evidencias documentales directamente a cada hallazgo, para mantener un expediente digital completo y no perder ninguna fecha crítica.

Criterios de Aceptación:

- 59. El sistema envía notificaciones por correo institucional y dentro del aplicativo ante: asignación de tarea, vencimiento en 5 días, vencimiento hoy y tarea vencida.
- 60. El auditor puede adjuntar archivos de hasta 50 MB por evidencia (PDF, DOCX, XLSX, JPG, PNG, ZIP).
- 61. Cada evidencia queda vinculada a un hallazgo específico con metadatos: fecha de obtención, fuente, descripción y auditor que la adjuntó.
- 62. El sistema indexa el contenido de los documentos adjuntos para búsqueda full-text.
- 63. El auditor puede marcar una evidencia como 'clasificada' para restringir su visibilidad a auditores del mismo equipo.

Definición de Terminado (DoD): Sistema de notificaciones probado en ambiente de staging con correos reales. Carga de evidencias probada con archivos de distintos formatos y tamaños.

HU-13 | Generación automática de informes de auditoría

Prioridad: Alta

Módulo
M06 — Informes

Rol
Auditor Líder

Sprint
Sprint 3-4

RF Relacionados
RF-25, RF-26

Historia de Usuario:

Como Auditor Líder, quiero que el sistema genere automáticamente el informe de auditoría siguiendo las plantillas oficiales de la CGN, para reducir el tiempo de elaboración y garantizar que todos los informes cumplan el formato institucional exigido.

Criterios de Aceptación:

- 64. El sistema genera informes usando la plantilla de la Resolución Orgánica 7350 CGN con: carátula, introducción, alcance, hallazgos, opinión y conclusiones.

- 65. El informe se pobla automáticamente con los datos del proceso auditor: entidad, período, equipo, hallazgos validados y evidencias.
- 66. El informe exportado en PDF incluye firma digital con certificado de la ONAC.
- 67. El informe en DOCX es editable por el auditor líder para personalización de las secciones narrativas.
- 68. El sistema genera un número consecutivo único y oficial para cada informe definitivo.
- 69. El auditor líder debe aprobar el informe electrónicamente antes de que pueda ser enviado a la entidad auditada.

Definición de Terminado (DoD): Informe generado revisado por auditor líder CGN y validado contra 3 informes reales históricos. Firma digital probada con certificado ONAC real.

HU-14 Reportes ejecutivos y dashboards de gestión			Prioridad: Media
Módulo M06 — Informes	Rol Director / Gerente	Sprint Sprint 4	RF Relacionados RF-27, RF-28
Historia de Usuario: <i>Como Director de Control Fiscal, quiero consultar dashboards ejecutivos con indicadores de gestión de la auditoría en tiempo real, para tomar decisiones estratégicas basadas en datos actualizados sobre el desempeño del proceso auditor.</i>			
Criterios de Aceptación: 70. El dashboard muestra: número de auditorías activas/cerradas, hallazgos por nivel de riesgo, valor fiscal comprometido, cumplimiento de plazos y productividad por equipo. 71. Todos los indicadores tienen filtros por período, tipo de auditoría, sector económico y entidad auditada. 72. El director puede exportar cualquier gráfico o tabla en PDF o XLSX. 73. El dashboard se actualiza automáticamente cada 15 minutos. 74. El sistema permite crear vistas personalizadas guardando la configuración de filtros preferida.			
Definición de Terminado (DoD): Dashboard validado con el Director de Control Fiscal en sesión de demo. Exportación en PDF y XLSX probada. Tiempo de carga < 3 segundos.			

HU-15 Registro y gestión de hallazgos fiscales			Prioridad: Alta
Módulo M07 — Trazabilidad	Rol Auditor de Campo / Auditor Líder	Sprint Sprint 3	RF Relacionados RF-29, RF-30
Historia de Usuario: <i>Como Auditor de Campo, quiero registrar detalladamente cada hallazgo fiscal con su evidencia, norma infringida, cuantificación económica y responsable, para garantizar que el expediente de auditoría sea completo, trazable y defendible jurídicamente.</i>			
Criterios de Aceptación: 75. El sistema permite registrar hallazgos con: título, descripción detallada, norma(s) infringida(s) con cita exacta, monto fiscal estimado (metodología de cuantificación), evidencias adjuntas y presunto responsable. 76. Los hallazgos se clasifican por tipo: Hallazgo Fiscal, Hallazgo Disciplinario, Hallazgo Administrativo y Hallazgo Penal. 77. El sistema crea automáticamente un plan de mejoramiento con fecha límite propuesta al validar un hallazgo.			

- 78. El responsable de la entidad auditada puede ser notificado del hallazgo mediante oficio generado automáticamente.
- 79. El sistema lleva trazabilidad completa: cada cambio de estado del hallazgo queda registrado con usuario, fecha y justificación.

Definición de Terminado (DoD): Flujo de hallazgo probado de extremo a extremo. Revisado por auditor líder y especialista legal CGN. Sin errores en cuantificación con 10 casos de prueba.

HU-16 Seguimiento a planes de mejoramiento			Prioridad: Media
Módulo M07 — Trazabilidad	Rol Auditor Líder / Auditor de Campo	Sprint Sprint 4	RF Relacionados RF-31, RF-32
Historia de Usuario: <i>Como Auditor Líder, quiero hacer seguimiento automatizado a los planes de mejoramiento comprometidos por las entidades auditadas, recibiendo alertas de vencimiento oportunas, para garantizar que los hallazgos no queden sin subsanar.</i>			
Criterios de Aceptación: 80. El sistema envía alertas automáticas a 30, 15 y 5 días antes del vencimiento de un plan de mejoramiento. 81. El auditor puede registrar avances parciales en el plan con porcentaje de cumplimiento y evidencias de avance. 82. El sistema genera una línea de tiempo visual con el historial completo de cada hallazgo: registro → notificación → plan → avances → cierre. 83. Al vencer el plazo sin cumplimiento, el sistema escala automáticamente al auditor líder con un resumen del incumplimiento. 84. El sistema calcula y muestra el índice de efectividad de cierre de hallazgos por entidad y por período.			
Definición de Terminado (DoD): Alertas de vencimiento probadas en ambiente de staging. Línea de tiempo revisada por auditor líder CGN con datos reales anonimizados.			

HU-17 Seguridad de datos y cifrado de la información			Prioridad: Alta
Módulo M08 — Seguridad	Rol Administrador / Oficial de Seguridad	Sprint Sprint 1	RF Relacionados RF-34, RF-35, RF-36
Historia de Usuario: <i>Como Oficial de Seguridad de la Información, quiero que el sistema cifre todos los datos sensibles tanto en tránsito como en reposo, implemente enmascaramiento por roles y genere reportes mensuales de seguridad, para cumplir con el Marco de Seguridad Digital del MINTIC y proteger la información fiscal confidencial.</i>			
Criterios de Aceptación: 85. Toda comunicación entre el cliente y el servidor usa TLS 1.3; las versiones anteriores son rechazadas. 86. Los datos en reposo (base de datos, backups, logs) se cifran con AES-256. 87. En interfaces de usuarios con bajo privilegio (Auditor de Campo viendo otra auditoría), los datos sensibles (cédulas, NIT, montos específicos) aparecen enmascarados (ej: ***-***-7890).			

- 88. El sistema ejecuta escaneos automáticos de vulnerabilidades mensuales y genera un informe de seguridad.
- 89. Antes del despliegue en producción, se realiza una prueba de penetración (pentest) externa con reporte formal.
- 90. Los resultados del pentest con vulnerabilidades críticas o altas deben ser remediados antes del go-live.

Definición de Terminado (DoD): Pentest externo completado sin vulnerabilidades críticas abiertas. Revisión de cifrado aprobada por oficial de seguridad CGN. Cumplimiento Decreto 1008/2018 certificado.